



Asociación Profesional de Cuerpos Superiores
de Sistemas y Tecnologías de la Información
de las Administraciones Públicas.

**Temario para la preparación
de la Oposición al Cuerpo Superior
de Sistemas y Tecnologías
de la Información
de la Administración del Estado.**

TEMAS ESPECÍFICOS – BLOQUE B

II. Tecnología básica

***Tema 79. El cifrado. Algoritmos de cifrado simétricos y
asimétricos. La función hash. El
notariado***

AUTOR: María Teresa Avelino Carmona
REVISOR: Xavier González Sanz

Actualización: Junio 2026

ÍNDICE

1	INTRODUCCIÓN	4
1.1	CRITOSISTEMAS	4
1.2	CRITOGRAFÍA CLÁSICA VERSUS MODERNA	5
1.3	CIBERSEGURIDAD Y CRITOGRAFÍA	7
1.3.1	ESQUEMA NACIONAL DE SEGURIDAD	8
1.3.2	OTRA NORMATIVA Y ESTÁNDARES	8
2	CRITOGRAFÍA DE CLAVE SIMÉTRICA.....	10
2.1	CIFRADO DE FLUJO	11
2.2	CIFRADO DE BLOQUE.....	12
2.2.1	AES	13
2.2.2	COMPARATIVA CIFRADO EN FLUJO VERSUS EN BLOQUE	13
3	FUNCIONES RESUMEN	14
3.1.1	ALGORITMOS MÁS COMUNES.....	14
4	CRITOGRAFÍA DE CLAVE ASIMÉTRICA	15
4.1	CIFRADO CON CLAVE PÚBLICA	15
4.2	FIRMA DIGITAL	15
4.3	SELLO DIGITAL.....	17
4.4	INFRAESTRUCTURA PKI, CERTIFICADOS DIGITALES Y SSI	18
5	COMPARATIVA ENTRE CRITOGRAFÍA SIMÉTRICA Y ASIMÉTRICA.....	19
5.1	CRITOSISTEMAS HÍBRIDOS	19
5.1.1	TLS.....	19
5.1.2	PGP / GPG	19
5.1.3	S/MIME (SECURE/MULTIPURPOSE INTERNET MAIL EXTENSIONS)	19
5.1.4	WHATSAPP / SIGNAL	20
5.1.5	SSH (SECURE SHELL)	20
5.1.6	IPSEC (INTERNET PROTOCOL SECURITY) EN MODO TÚNEL	20
5.1.7	CIFRADO DE PDF Y OFFICE (CON CERTIFICADOS)	20
5.2	COMPARATIVA	20
6	EL NOTARIADO Y EL SELLADO DE TIEMPO.....	22
6.1	FIRMA ELECTRÓNICA	22
6.2	SELLADO DE TIEMPO	23
6.3	NOTARIO DIGITAL TSA	23

7	CRIPTOANÁLISIS, MATEMÁTICAS Y EFICIENCIA COMPUTACIONAL	25
7.1	CRIPTOANÁLISIS	25
7.2	FUNDAMENTOS MATEMÁTICOS	25
7.3	EFICIENCIA COMPUTACIONAL	26
7.4	MÉTRICAS PARA IMPLEMENTACIÓN	27
8	TENDENCIAS A FUTURO DE LA CRIPTOGRAFÍA	28
8.1	CRIPTOGRAFÍA PQC	28
8.2	CRIPTOAGILIDAD Y SECRETOS EFÍMEROS	28
8.3	CRIPTOGRAFÍA HOMOMÓRFICA	29
8.4	CRIPTOGRAFÍA DE GESTIÓN DE LA IDENTIDAD	29
9	RESUMEN ESQUEMÁTICO	30
10	GLOSARIO	31
11	TEST	33
11.1	PREGUNTAS DE TEST	33
11.2	SOLUCIONES A LAS PREGUNTAS DE TEST	36
12	BIBLIOGRAFÍA	37
12.1	BIBLIOGRAFÍA BÁSICA	37
12.2	BIBLIOGRAFÍA PARA AMPLIAR EL TEMA	37

1 Introducción

Nuestro mundo actual, no sólo el virtual o el TIC sino en general, sería inconcebible sin el uso del cifrado, pero ciertamente la criptografía se utiliza desde hace aproximadamente 4.000 años.

La siguiente figura es una infografía resumen de la evolución de la criptología.



Figura 1: Historia de la criptología

- **Codificación jeroglífica:** Usada por los egipcios.
- **Escítala griega:** Ejemplo de primer cifrado de transposición cilíndrica (se enrollaba una tira de cuero o papiro alrededor de un bastón (la Escítala) de un diámetro específico y se escribía el mensaje longitudinalmente, de modo que al desenrollarla las letras quedaban desordenadas. Para descifrarlo, había que nuevamente enrollar el mensaje en un bastón del mismo diámetro).
- **Cifrado César:** Sustitución monoalfabética.
- **Criptanálisis:** Ejemplo: Piedra de Rosetta. Ejemplo de primer ataque de texto en claro **conocido** (Known-Plaintext Attack) a gran escala. Al tener el mismo decreto en tres escrituras (jeroglífico, demótico y griego antiguo), Champollion pudo descifrar la parte correspondiente a la escritura jeroglífica.
- **Máquinas mecánicas y electromecánicas** (siglo XIX a mediados del XX): Automatizaron el proceso de sustitución de letras. Ejemplo la máquina Enigma, cuya ruptura por The Bombe creada por Alan Turing benefició la victoria aliada en la II Guerra Mundial.

1.1 Criosistemas

Cifrar es el **proceso de transformar información legible en información ilegible, siendo recuperable si se conoce el proceso (algoritmo y claves) usadas.**

Es importante diferenciar entre codificación y cifrado: Codificar es establecer una correspondencia entre alfabetos, como ocurre por ejemplo con el Código ASCII donde cada número corresponde a un símbolo en dicho alfabeto.

El cifrado no es una mera asignación de valores en un alfabeto, sino que consta de una serie de elementos en lo que se conoce como **criptosistema**.

Un **criptosistema** consta de un **algoritmo**, que es una función matemática que depende de un valor variable que es la **clave**, y asigna a cada **texto en claro** (mensaje que se quiere cifrar), un **mensaje cifrado** que se ha obtenido aplicando el algoritmo con la clave fijada de antemano.

1.2 Criptografía clásica versus moderna

La **criptografía clásica** abarca los **métodos de cifrado manuales o mecánicos inventados antes de la era de la computación**, donde la seguridad dependía básicamente de la complejidad, pero, sobre todo, de la ocultación del algoritmo. **A diferencia de la criptografía moderna, la clásica opera sobre alfabetos, mientras que la moderna opera sobre bits.**

Aunque hoy en día no se utiliza ya, su estudio es esencial para entender los fundamentos de la criptografía moderna y la ciberseguridad, ya que introdujo los conceptos clave: **sustitución (reemplazar caracteres)**, **transposición (reordenar caracteres)**, **clave secreta**, **confidencialidad y criptoanálisis**.

- **Cifrados monoalfabéticos:** Ejemplo, cifrado César. Utilizan un único alfabeto de sustitución donde cada letra del texto original se reemplaza siempre por la misma letra cifrada, lo que los hace muy vulnerables al análisis de frecuencias de un idioma.
- **Cifrados polialfabéticos** emplean múltiples alfabetos de sustitución de forma cíclica mediante una palabra clave. El más famoso es el cifrado de Vigenère (siglo XVI). **Enigma** es una evolución porque emplea además rotores intercambiables (mecánica).

Los cifrados polialfabéticos ofrecen **una seguridad mucho mayor respecto a los monoalfabéticos**, dado que el análisis de frecuencia (la observación de que ciertas letras aparecen más a menudo), permitió hace siglos ya romper los cifrados monoalfabéticos.



Figura 2: Rompiendo el cifrado de Enigma. Infografía

La **criptografía moderna** comienza con el **uso de computadoras** en la década de los 70.

Primeramente, nace el **primer algoritmo de cifrado simétrico moderno: DES** (Data Encryption Standard) que introduce las nuevas operaciones S-Boxes (sustitución) y las P-Boxes (permutación) aplicadas a bloques de bits.

El **protocolo Diffie-Hellman** resuelve el "problema de la distribución de claves": permite que dos personas puedan comunicarse de forma segura sin haberse conocido antes ni compartido una clave secreta. Este es el primer caso para implementar la Criptografía Asimétrica o de clave pública en Internet.

A continuación, surgió **RSA, primer algoritmo para cifrado (asimétrico) como firma digital**.

Con la explosión de Internet, DES se desaconseja ante la posibilidad de romperlo.

En el año 2000, tras un concurso público internacional, se eligió el algoritmo **AES** (Advanced Encryption Standard) como sustituto. A diferencia de sus predecesores, AES utiliza un modelo matemático

(Cuerpo de Galois) más avanzado que DES. Es extremadamente eficiente tanto en software como en hardware, es seguro y es más usado en la actualidad.

Es preciso remarcar que el cambio fundamental a partir del año 2000 es el de la **estandarización y transparencia de algoritmos**. La robustez de un algoritmo ya no se basa en su desconocimiento sino en la dificultad de su ruptura.

Otro cambio fundamental de la criptografía moderna es el de su uso para dimensiones de seguridad distintas a la de la confidencialidad. Por ejemplo, las **funciones hash** (como SHA), permiten asegurar la integridad de los datos.

También se considera la eficiencia computacional, por ejemplo, la Criptografía de Curva Elíptica (ECC), ofrece la misma seguridad que el RSA, pero con claves mucho más pequeñas, algo vital para que, por ejemplo, un teléfono móvil no gaste toda su batería cifrando mensajes.

Operación	Criptografía Clásica	Criptografía Moderna
Aritmética	Sumas y restas simples (Módulo 26).	Álgebra de campos finitos (Cuerpos de Galois).
Lógica	No se usaba.	XOR, AND, OR (Lógica binaria).
Unidad de medida	Letras del alfabeto.	Bits y Bytes.
Complejidad/ rotura	Análisis de frecuencias (ver qué letra sale más veces).	Factorización de números primos o curvas elípticas.

Tabla 1: Comparativa entre criptografía clásica y moderna hasta el año 2020

La definición del **secreto perfecto** fue introducida por Shannon en 1949 y sigue vigente hasta nuestros días: **Un sistema criptográfico implementa un secreto perfecto si, aunque un atacante intercepte el mensaje cifrado y tenga potencia de cálculo infinita, no puede obtener ninguna información sobre el contenido original.**

Esto obviamente era posible de conseguir antes de la computación cuántica, porque mediante complejos algoritmos matemáticos, el ataque por fuerza bruta requería un tiempo de décadas o siglos.

Aunque lo veremos en más detalle al final de este tema, en la actualidad la criptografía se enfrenta a retos importantes:

- **La amenaza cuántica:** La ruptura de los secretos en Internet se acortaría de décadas o siglos a días, horas o minutos. Cuando este sea posible, se dice que habremos alcanzado el "Q Day". Se estima entorno al 2030, pero todo depende de la construcción de ordenadores cuánticos potentes. Ante esta amenaza, se ha planteado la criptografía poscuántica (PQC).
- **Harvest now, decrypt later:** Aunque un atacante no haya podido romper a día de hoy nuestros secretos, es posible que, sabiendo que pronto será posible, esté guardando esta información todavía ininteligible, para descifrarla más tarde. La única manera de combatirlo es mediante el uso de **secretos efímeros y la criptoagilidad**.
- **La confidencialidad de los datos en la Nube:** Se plantea el dilema de mantener la confidencialidad de los datos que precisan ser gestionados en la Nube por terceros. Para conseguir resolver este problema, se plantea el cifrado homomórfico.



Figura 3: Evolución histórica de la criptografía

1.3 Ciberseguridad y criptografía

La criptografía es el pilar de la ciberseguridad, ya que no se concibe la segunda sin la primera. Aunque el primer uso que dio históricamente fue el de la confidencialidad, ha evolucionado para proporcionar seguridad también a nuestra identidad, trazabilidad de las transacciones (como ocurre por ejemplo con blockchain) o firma digital, dando validez y seguridad jurídica a nuestras actuaciones y contratos.

A continuación, se detalla cómo ayuda en sectores clave y luego, como opera en cada dimensión de la seguridad:

- **Aplicaciones de Mensajería:** WhatsApp, Telegram o Signal utilizan el cifrado de extremo a extremo (E2EE). Si bien Signal emplea medidas adicionales y se considera más seguro que los otros dos, la idea es que se cifra en origen y se comunican cifrados los datos, mediante claves que sólo origen y destino comparten.
- **Banca y Comercio Electrónico:** Es el uso más crítico. La criptografía en la banca electrónica garantiza la confidencialidad, integridad y autenticidad de las transacciones mediante el cifrado de datos (SSL/TLS), firmas digitales y tokenización. Protege la información sensible durante el tránsito y almacenamiento. Además, la firma electrónica permite autorizar transferencias bancarias con la misma validez legal que una firma manuscrita.
- **Sanidad:** En la **historia clínica electrónica**, la criptografía protege la privacidad del paciente. Se utiliza para el control de acceso (solo personal autorizado descifra el dato) y para asegurar que las recetas electrónicas o los resultados de pruebas no sean alterados durante su envío.
- **Criptomonedas y Blockchain:** Aquí la criptografía es la base del sistema. Las funciones hash encadenan los bloques de transacciones de forma inalterable, mientras que las claves públicas y privadas gestionan la propiedad de los activos sin necesidad de un banco central.



Figura 4: Aplicaciones de la Criptografía en la actualidad

1.3.1 Esquema Nacional de Seguridad

La criptografía es la herramienta técnica que permite materializar los principios del Esquema Nacional de Seguridad (ENS):

- **Confidencialidad:** Es el objetivo primario. Mediante algoritmos simétricos (AES) o asimétricos (RSA, ECC), se garantiza que la información solo sea accesible para quienes poseen la clave de descifrado. Impide que terceros (curiosos o atacantes) lean los datos.
- **Integridad:** Se protege mediante funciones Hash (SHA-256). Si un solo bit de un archivo médico o una transferencia bancaria cambia, el "resumen" resultante será totalmente distinto. Esto permite detectar cualquier modificación malintencionada o accidental.
- **Autenticidad:** Asegura que quien dice enviar el mensaje es quien realmente es. Se logra mediante el uso de la clave privada del emisor para generar una firma que cualquiera puede verificar con su clave pública.
- **No Repudio:** Vinculado a la firma electrónica. Gracias a la criptografía asimétrica, el emisor no puede negar haber enviado un documento o realizado una acción, ya que solo él posee la clave privada que generó esa firma única.
- **Trazabilidad:** Al combinar firmas digitales y sellos de tiempo, se puede reconstruir el camino de un dato (quién lo tocó y cuándo), garantizando que el historial de acciones sea auditable y veraz.
- **Disponibilidad:** Aunque la criptografía suele asociarse a la ocultación, también protege la disponibilidad. Por ejemplo, las firmas digitales en las actualizaciones de software evitan que un atacante introduzca malware que bloquee los sistemas, asegurando que el servicio siga operativo y confiable.

1.3.2 Otra normativa y estándares

La protección de datos también hacer referencia explícita o implícita al **uso de cifrado de datos para proteger la privacidad de la información**.

Artículos clave que hacen referencia al cifrado

- Artículo 32 del RGPD, que se incorpora en la LOPDGDD:

Texto relevante (resumido y adaptado al contexto español):

*“Teniendo en cuenta el estado de la técnica, los costes de aplicación y la naturaleza, alcance, contexto y fines del tratamiento, el responsable y el encargado del tratamiento pondrán en práctica medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, incluidas, entre otras, la seudonimización y el **cifrado de datos personales**.”*

Interpretación: aquí el cifrado aparece como ejemplo explícito de medida técnica para proteger los datos.

- Artículo 87 LOPDGDD – Medidas de seguridad:
Refuerza el Art. 32 RGPD y señala:

*“Los responsables y encargados de tratamiento deberán aplicar, entre otras, **medidas como cifrado de los datos personales** para garantizar su confidencialidad.”*

Pero no sólo la protección de datos hace esta mención al uso de la criptografía. Más recientemente la **Directiva NIS2** (Network and Information Security 2), que es la actualización de la Directiva NIS de la UE sobre ciberseguridad, también vincula la ciberseguridad con medidas técnicas, y la criptografía aparece de manera implícita como control recomendado para proteger sistemas críticos.

En general los estándares de mayor aplicación a nivel internacional como la **ISO/IEC 27001** (Gestión de la seguridad de la información) establece que se deben aplicar controles criptográficos para proteger la confidencialidad, integridad y disponibilidad de la información.

El **NIST** (National Institute of Standards and Technology, EE.UU.) en sus publicaciones sobre ciberseguridad como son las normas NIST SP 800-53 y SP 800-175 detallan controles de seguridad que incluyen: Algoritmos de cifrado, firmas digitales y la gestión de las claves criptográficas.

Además, las normas FIPS-140 definen cómo deben construirse los módulos hardware criptográficos.

Como conclusión de este capítulo es preciso recordar por tanto que:

- **La criptografía moderna es el pilar técnico del ENS y el RGPD** para garantizar la seguridad de los sistemas que se diseñan en la Administración.
- Al implementar nuevos sistemas, **un gestor TIC debe priorizar el uso de algoritmos estándar como AES y ECC por su eficiencia**, asegurando el correcto uso de la criptografía tanto para la autenticidad como para las firmas digitales.
- **Ante el reto del "Q-Day", la estrategia actual de la Administración exige adoptar la criptoagilidad** para transitar hacia soluciones poscuánticas que protejan los datos frente a futuras amenazas de computación avanzada.
- **La Administración en España sigue las directrices del Centro Criptológico Nacional (CCN-PYTEC)** en lo tocante a criptografía, quien a su vez se alinea con el proceso de estandarización del NIST estadounidense. Dado que los algoritmos definitivos se han estandarizado recientemente, las infraestructuras oficiales están integrándolos primero en entornos de prueba o integrando soluciones híbridas.

2 Criptografía de Clave Simétrica

Es la más antigua y eficiente tanto desde el punto de vista de su implementación como computacionalmente. Se basa en que emisor y receptor comparten **una única clave** tanto para cifrar como para descifrar.

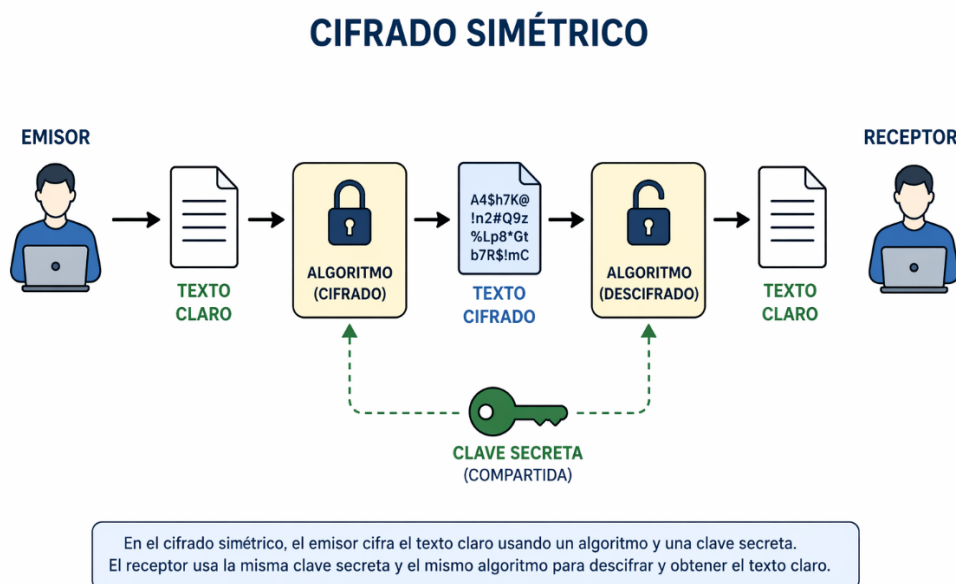


Figura 5: Esquema de cifrado y descifrado

Si bien esta criptografía requiere menos recursos computacionales y es más eficiente en general, **presenta el gran problema del envío de la clave por un canal seguro antes de empezar la comunicación.**

Además, si cada usuario comparte una clave, el número de claves en el sistema sería el número de combinaciones posibles dos a dos, lo cual complica la gestión y custodia de las claves.

Uso principal: Cifrado de grandes volúmenes de datos (discos duros, bases de datos) debido a su gran velocidad. Uso militar en circuitos cerrados de información clasificada.

Los algoritmos de clave simétrica para cifrado, se dividen en dos tipos: De flujo y de bloque.

Pero tanto unos como otros usan una o varias combinaciones de las siguientes operaciones matemáticas:

- **XOR:** Si el texto plano M se combina con una clave K (de la misma longitud) usando XOR para obtener M' , el descifrado se realiza aplicando XOR nuevamente a ese mensaje cifrado con la misma clave, ya que $M \text{ XOR } K \text{ XOR } K = M$.
- **Sustitución (S-Boxes):** Los bits del mensaje se reemplazan por otros bits siguiendo una tabla de búsqueda definida por la clave, lo que rompe los patrones del texto.
- **Permutación (P-Boxes):** Los bits se reordenan o transponen de posición para lograr difusión, asegurando que un cambio en un bit de entrada afecte a muchos bits de salida.
- **Rotación (Circular Shift):** Los bits se desplazan hacia la izquierda o derecha un número determinado de posiciones.

Además de estas operaciones hay que tener en cuenta los Modos de Operación (ej. CBC, GCM): **Los modos de operación definen cómo aplicar el algoritmo a mensajes más largos que el bloque.** El modo CBC usa XOR con el bloque anterior, mientras que GCM proporciona cifrado y autenticación.

2.1 Cifrado de flujo

Un algoritmo de cifrado de flujo (stream cipher) es un tipo de cifrado simétrico que **cifra los datos bit a bit o byte a byte, generando un flujo de clave que se combina con el texto en claro.**

Sus elementos principales son:

- **Clave secreta (key):** Es el valor inicial compartido entre emisor y receptor. A partir de ella se genera todo el cifrado.
- **Vector de inicialización (IV) o nonce** (opcional pero muy común): Es un valor no secreto que se usa junto con la clave para garantizar que el flujo de cifrado sea distinto incluso si se reutiliza la misma clave. Evita patrones repetidos.
- **Generador de flujo de clave (keystream generator):** Es el núcleo del algoritmo. Produce una secuencia pseudoaleatoria de bits o bytes (el keystream) a partir de la clave (y el IV si existe). Ejemplos de construcción de este generador son los registros de desplazamiento, funciones aritméticas, o cifradores de bloque en modo stream.

Operación de combinación (normalmente XOR):

- Cifrado: $C = P \oplus K$
- Descifrado: $P = C \oplus K$

Donde P es el texto en plano (sin cifrar) y C el texto cifrado. K (secuencia cifrante) es el resultado correspondiente a aplicar el generador de flujo de clave a la clave k y al vector iv .

El cifrado obtenido así es extremadamente rápido pues la operación XOR se realiza de forma muy sencilla. Y el descifrado es también muy sencillo y rápido pues basta con volver a aplicar XOR al mensaje cifrado, con la misma clave.

Este tipo de cifrado es ideal para transmisiones en tiempo real y cifrado de datos de longitud variable sin necesidad de relleno (padding).

Existen dos categorías principales de algoritmos respecto a cómo según cómo se genera el flujo:

- **Síncronos:** El flujo de claves se genera independientemente del texto plano y del texto cifrado. Si se pierde un bit en la transmisión, el receptor pierde la sincronía.
- **Auto-sincronizantes:** El flujo de claves depende de bits anteriores del texto cifrado. Si se pierde un bit, el error solo afecta a unos pocos bits siguientes antes de recuperar la armonía.

A pesar de su gran seguridad, existe no obstante un riesgo muy grande si no se opera correctamente: El riesgo por “Nonce Reuse”. Esto es: **Nunca se debe usar la misma clave y el mismo IV para cifrar dos mensajes distintos.** Si un atacante intercepta dos textos cifrados con el mismo flujo, puede aplicar XOR entre ellos y eliminar la clave, dejando el texto plano expuesto

En entornos móviles y software el algoritmo de referencia es **ChaCha20**. En Infraestructura y Servidores, AES-GCM sigue siendo el estándar.

Casi todos los microprocesadores modernos incluyen **AES-NI** en su juego de instrucciones, lo que hace que AES-GCM implementado en hardware consuma poca CPU.

El reto Post-Cuántico (PQC): Aunque estos algoritmos son simétricos y más resistentes a la computación cuántica que los asimétricos (como RSA), la recomendación actual es **usar claves de 256 bits para garantizar la seguridad a largo plazo** frente a algoritmos de búsqueda cuántica (como el algoritmo de Grover).

A continuación, se muestra una tabla con los algoritmos más conocidos

Tabla 2: Algoritmos de cifrado en flujo

Algoritmo	Robustez	Hardware o Software	Aplicación Principal	Recomendado
Chacha20	Muy Alta.	Software	Más rápido que AES en software, ideal para dispositivos embebidos y sistemas IoT. VPN (WireGuard), Móviles, TLS 1.3, Google Services	Estándar de oro. Recomendado por el CCN
AES-GCM	Muy Alta.	Ambos, pero está pensado para chips embebidos (AES-NI).	Es un cifrado de bloque realmente funcionando como de flujo. Navegación web (HTTPS), Wi-Fi (WPA3), discos duros.	Líder en la industria
AES-CTR	Alta.	Se puede usar tanto en software como hardware.	SSH, streaming de video de alta velocidad. Muy rápido y paralelizable.	Uso condicionado (Requiere MAC externa).
SNOW 3G / ZUC	Alta.	Hardware Optimizado para hardware de red y chips de radio.	Seguridad en redes 4G LTE y 5G. Diseñados específicamente para telecomunicaciones	Recomendado (Ámbito teleco).
Grain / MICKEY	Media. Diseñados para ser "ligeros".	Hardware: Consumo de energía extremadamente bajo.	Dispositivos IoT críticos, sensores médicos, etiquetas RFID.	Especializado (Entornos restringidos).
RC4	Nula. Roto por múltiples ataques.	Rápido pero inseguro.	Antigua (WEP, TLS antiguo).	PROHIBIDO.

Tabla 2: Algoritmos de cifrado en flujo

2.2 Cifrado de bloque

En vez de cifrar todo el mensaje de golpe, se divide en bloques del mismo tamaño (64, 128, etc.) y se rellena si es preciso los bloques incompletos con valores prefijados (padding).

Para que sea seguro, un algoritmo de bloque aplica repetidamente dos principios definidos por Claude Shannon:

- **Confusión:** Hace que la relación entre la clave y el texto cifrado sea lo más compleja posible (mediante sustituciones, llamadas S-Boxes).
- **Difusión:** Dispersa la influencia de cada bit del texto plano sobre muchos bits del texto cifrado (mediante permutaciones). Si se cambia un solo bit del mensaje original, el bloque cifrado debería cambiar por completo (el "efecto avalancha").

Como los mensajes suelen ser más largos que un solo bloque (128 bits), se precisa una estrategia para "encadenar" esos bloques. Los más comunes son:

- **ECB (Electronic Codebook):** Cada bloque se cifra de forma independiente con la misma clave. Es inseguro para datos con patrones (como imágenes), porque bloques idénticos producen resultados idénticos.
- **CBC (Cipher Block Chaining):** Cada bloque de texto plano se combina (XOR) con el bloque cifrado anterior antes de cifrarse. Esto oculta patrones, pero no permite el procesamiento en paralelo.
- **GCM (Galois/Counter Mode):** Es el más moderno y eficiente. Permite cifrar en paralelo y además ofrece autenticidad (asegura que el mensaje no ha sido manipulado).

2.2.1 AES

La historia del AES (Advanced Encryption Standard) es relevante, ya que es el paradigma de la criptografía moderna, en lo tocante a la estandarización. AES nació de un concurso público convocado por el NIST en el año 1997, algo poco común hasta entonces.

En esta convocatoria se indicaban que los algoritmos que se presentaran debían cumplir los requisitos:

- Ser de **dominio público**, disponible para todo el mundo.
- Ser un algoritmo de **cifrado simétrico y soportar bloques de, como mínimo, 128 bits**.
- Ser **implementable tanto en hardware como en software**.

Tres años después quedó finalmente como ganador el algoritmo RINJDAEL. Básicamente, el algoritmo repite varias rondas de cuatro operaciones matemáticas básicas:

- **SubBytes** – reemplaza cada byte con otro usando una tabla llamada S-box.
- **ShiftRows** – desplaza las filas del bloque de datos para mezclar la posición de los bytes.
- **MixColumns** – mezcla los bytes dentro de cada columna del bloque, aumentando la difusión.
- **AddRoundKey** – combina el bloque con una porción de la clave expandida (llamada “clave de ronda”) usando XOR.

La última ronda omite MixColumns, pero sigue haciendo las demás operaciones.

Características de AES:

- **Rapidez:** Está diseñado para ser muy eficiente tanto en software (ordenadores) como en hardware (chips de tarjetas bancarias).
- **Seguridad:** Hasta hoy, no se conoce ningún ataque práctico que pueda romper AES si se usa correctamente.
- **Efecto Avalancha:** Si se cambia un solo bit en el mensaje original, el resultado cifrado cambia más de la mitad respecto al resultado anterior. **Es imposible encontrar patrones.**

Posteriormente el NIST estandarizó este algoritmo como AES : NIST FIPS-197 con longitudes de clave de 128, 192 y 256 bits.

Un punto importante que supuso AES fue la estandarización del cifrado en hardware. Tanto para criptografía simétrica como en el siguiente capítulo de criptografía asimétrica y en entornos empresariales se usan los **Hardware Security Module (HSM)**: dispositivo físico de computación que protege y gestiona claves digitales, realiza funciones de cifrado y descifrado, y ofrece una autenticación fuerte.

2.2.2 Comparativa cifrado en flujo versus en bloque

Característica	Cifrado de Flujo	Cifrado en Bloque
Unidad de datos	Bit o Byte	Bloque fijo (ej. 128 bits)
Velocidad	Muy alta	Media/Alta
Complejidad	Baja (XOR)	Alta (Rondas matemáticas)
Uso común	Streaming, Redes	Archivos en reposo
Algoritmo típico	ChaCha20	AES

Tabla 3: Comparativa cifrado en flujo o de bloque

Como resumen de este capítulo es preciso indicar *que AES (con claves de 256 bits para garantizar la seguridad a largo plazo) es el algoritmo de referencia de clave simétrica para proteger la información en el Esquema Nacional de Seguridad*. Se recomienda usarlo con modos de operación modernos (como GCM) que no solo cifran, sino que también aseguran que nadie haya manipulado el mensaje (autenticidad). Además, si se considera usarlo para infraestructuras con cierta relevancia con alto número de usuarios, se aconseja usarlo en hardware e incluso con HSMs. En comunicaciones móviles, **ChaCha20 (flujo)** al consumir menos, es el idóneo.

3 Funciones resumen

Otro uso de la criptografía es el de las funciones resumen, que no se usan para cifrar textos sino para comprobar su integridad, verificando, por ejemplo, que un texto no ha sido alterado cuando se transmite o envía a través de redes inseguras. **Una función hash es un algoritmo que transforma datos de tamaño variable en un valor fijo**, generalmente llamado resumen o hash. **Este valor suele representarse como una cadena de números y letras en hexadecimal.**

Algoritmo hash	Longitud	Ejemplo: Hash de "Hola mundo"
MD5	128 bits / 32 hex	6cd3556deb0da54bca060b4c39479839
SHA-1	160 bits / 40 hex	943a702d06f34599aee1f8da8ef9f7296031d699
SHA-256	256 bits / 64 hex	a591a6d40bf420404a011733cfb7b190d62c65bf0bcda32b57b277d9ad9f146e

Tabla 4: Comparativas de hashes sobre un mismo ejemplo

Para que una función hash sea útil en seguridad, debe cumplir estas reglas:

- **Determinista:** Para una misma entrada, debe salir exactamente el mismo hash.
- **Resistencia a la preimagen (Irreversible):** Dada una salida, es matemáticamente imposible adivinar cual es el mensaje original.
- **Efecto Avalancha:** Si se cambia una sola letra del mensaje el hash resultante debe ser completamente distinto. Esto permite detectar si alguien ha alterado el mensaje original.
- **Resistencia a colisiones:** Es extremadamente difícil encontrar dos entradas diferentes que resulten el mismo hash.

Algunas aplicaciones en la práctica:

- **Guardar contraseñas:** Las páginas web y los sistemas operativos no guardan contraseñas en claro. Guardan el hash (algunos incluso añadiendo derivaciones o salt). Cuando se introduce una contraseña, el sistema calcula el hash y comprueba si coincide con el que tiene guardado. Si un hacker accediese al fichero de contraseñas, sólo vería códigos ininteligibles. Por eso cuando la olvidamos, el administrador sólo nos permite cambiarla (ya que ni él puede verla).
- **Verificar descargas:** Cuando descargamos un software, habitualmente viene acompañado de un código "Checksum" que suele venir en formato "SHA-256". Si este hash teórico del archivo que hemos bajado coincide con el que calculamos al descargarlo, el archivo es correcto.
- **Blockchain y Bitcoin:** Usan los hashes para "encadenar" los bloques. Cada bloque lleva el hash del anterior, de modo que si alguien intenta cambiar un dato del pasado, todos los hashes siguientes se rompen y la red alerta del intento de manipulación.
- **Indexación de grandes volúmenes de datos:** Usan tablas hash para acceder de forma rápida a los datos.

3.1.1 Algoritmos más comunes

- **MD5, SHA-1, RIPEMD-160:** Considerados inseguros: se han encontrado "colisiones" (dos archivos distintos con el mismo hash). **El CCN no los permite** para el ENS.
- **Familia SHA-2:** Comprende SHA-256, SHA-384 y SHA-512. SHA-256 es el que usa Bitcoin.
- **Familia SHA-3 (Keccak):** Es Versión más moderna que la SHA-2, y con una estructura matemática diferente para mayor seguridad, resistente a ataques cuánticos. La principal diferencia entre SHA-2 y SHA-3 radica en su estructura interna y resistencia a vulnerabilidades, no en la longitud de sus hashes.

Para cerrar este capítulo recuerda que las funciones hash no cifran, sino que generan un **resumen digital (digest) de longitud fija** mediante algoritmos matemáticos unidireccionales. Su aplicación es la verificación de la integridad de los datos, como parte inicial de una firma digital, para guardar contraseñas de forma segura o para indexar grandes volúmenes de datos (tablas hash). Recuerda también que el CCN aconseja utilizar SHA-2 o SHA-3.

4 Criptografía de Clave Asimétrica

También llamada **Criptografía de clave pública**, es la gran revolución que permitió Internet.

Cada usuario o identidad utiliza un **par de claves** vinculadas matemáticamente: una **pública** (que se puede repartir a todo el mundo) y una **privada** (que solo el dueño conoce).

Uso principal: Intercambio seguro de claves en entornos no confiables (como Internet), firma electrónica e identificación.

4.1 Cifrado con clave pública

Cuando se cifra con clave pública, el emisor cifra el mensaje con la clave pública del destinatario. Pero el destinatario descifra el mensaje con su clave privada. Y sólo este es capaz de descifrar el mensaje. La clave pública, puede ser distribuida a cualquier persona con la que se precise comunicarse. La clave privada, por el contrario, debe mantenerse completamente secreta.

La infografía muestra un ejemplo con dos interlocutores (*Alicia*, *Bernardo*).



Figura 6: Cifrado con clave pública. Alicia envía un mensaje cifrado a Bernardo y éste lo descifra

La clave pública puede compartirse libremente con cualquier persona, ya que únicamente sirve para cifrar información o verificar firmas, pero no permite descifrar los mensajes. Sólo quien posee la clave privada puede descifrar el mensaje.

Con la amenaza de ruptura por ataques con computación cuántica, cuando ocurra el Q-day, el atacante sí podrá descifrar por fuerza bruta el mensaje que el emisor envía al destinatario.

Este mecanismo descrito garantiza principalmente la confidencialidad.

4.2 Firma digital

La segunda infografía muestra **cómo funciona la firma digital**, cuyo objetivo principal no es ocultar el contenido del mensaje, sino demostrar quién lo ha enviado y garantizar que no ha sido modificado (lo que se conoce como No Repudio).

Veamos el concepto con un ejemplo entre dos interlocutores. Supongamos que *Bernardo* quiere enviar un mensaje a *Alicia* y necesita demostrar que realmente procede de él.

El proceso para la firma es el siguiente:

- *Bernardo* redacta el mensaje.
- Antes de enviarlo, *Bernardo* **calcula un resumen criptográfico del mensaje (hash)**. Como ya vimos en el capítulo anterior, el hash es una huella digital única del contenido. Si cambia una sola letra del mensaje, el hash resultante será completamente diferente.
- *Bernardo* **cifra ese hash utilizando su clave privada**.

Importante: **La clave privada en cuestión para cifrar el hash es la de firma, no la que utiliza para descifrar mensajes ni la que puede utilizar para autenticarse**, si bien técnicamente podría ser la misma, se desaconseja totalmente. De ahí que, por ejemplo, en el caso del DNI electrónico, se incorporan dos claves distintas (una para autenticación y la otra para firma).

El resultado de cifrar el hash con la clave privada se conoce como firma digital.

- *Bernardo envía a Alicia:*
 - El mensaje original.
 - La firma digital asociada.

El proceso para la verificación por parte de Alicia es como sigue:

- *Alicia recibe ambos elementos (mensaje y firma) y realiza dos operaciones:*
 - Calcula nuevamente el hash del mensaje recibido.
 - Descifra la firma digital usando la clave pública de Bernardo.

Si el hash calculado por Alicia coincide con el hash obtenido al verificar la firma, significa que: El mensaje realmente fue firmado por Bernardo y el contenido no ha sido alterado durante el envío.

Si los hashes no coinciden, *Alicia* sabe que ha ocurrido una de las dos siguientes posibilidades:

- El mensaje pudo haber sido modificado (interceptado y reescrito).
- O bien la firma no pertenece realmente a *Bernardo* (ha sido suplantado).



Figura 7: Ejemplo de verificación de la firma

La firma digital proporciona autenticidad, integridad y no repudio (bajo ciertas condiciones):

- Autenticidad: permite saber quién envió el mensaje.
- Integridad: asegura que el contenido no ha sido modificado.
- No repudio: Bernardo no puede negar posteriormente que firmó ese mensaje.

En España, la **plataforma VALId**e permite comprobar los documentos firmados digitalmente ya que realiza tres comprobaciones críticas de forma automatizada: **Integridad del contenido** (calculando el hash tal y como acabamos de ver), **Vigencia del Certificado de firma** (si el certificado se encuentra en vigor) y la **Cadena de confianza de dicho certificado** (si la Autoridad de Confianza que lo emitió está en buen estado y admitida en la UE conforme la normativa en vigor).

A continuación repasaremos los algoritmos de firma que se pueden utilizar:

Algoritmos de firma más antiguos:

- **DSA y El Gamal:** Basados en el problema del logaritmo discreto sobre aritmética modular.

- **RSA:** Basado en la dificultad de la factorización de enteros. Muy extendido históricamente en infraestructuras de clave pública (PKI) y firma de documentos, aunque en retroceso frente a alternativas más eficientes.

Algoritmos basados en curva elíptica (actualmente más usados):

- **ECDSA:** Basado en criptografía de curva elíptica. Muy utilizado en certificados digitales, TLS y sistemas modernos por su eficiencia y menor tamaño de clave frente a RSA.
- **EdDSA (Ed25519):** Variante moderna de firma sobre curvas elípticas, más segura frente a errores de implementación y muy eficiente. Cada vez más adoptada en sistemas actuales.

En cuanto a algoritmos PQC (poscuánticos):

- **CRYSTALS-Dilithium:** Basado en criptografía de retículos.
- **Falcon:** También basado en retículos, aunque con diferencias matemáticas respecto al anterior que lo hacen más ligero.
- **SPHINCS+:** Basado en funciones hash. Muy robusto desde el punto de vista teórico, aunque menos eficiente (firmas más grandes). Usado cuando se prioriza la seguridad a largo plazo.

4.3 Sello digital

Un sello digital se utiliza para demostrar que un documento es auténtico y que no ha sido modificado desde que fue emitido.

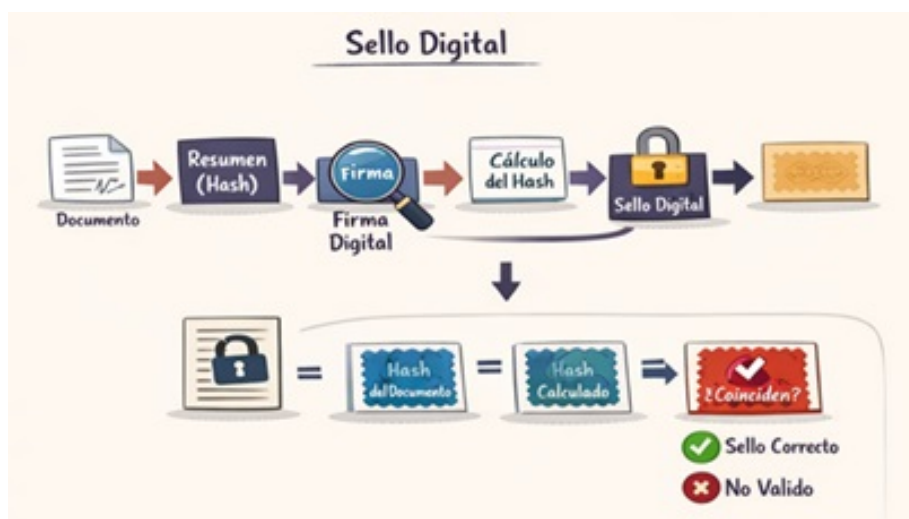


Figura 8: Verificación de la firma

El proceso es el siguiente: Se parte de un documento original.

- Se calcula el hash del documento completo.
- Ese hash se cifra utilizando la clave privada del emisor.
- El resultado es la firma digital o sello digital asociado al documento.
- El documento y el sello se envían juntos.

Cuando el receptor recibe el documento:

- Calcula el hash del documento recibido.
- Descifra la firma utilizando la clave pública del emisor.
- Obtiene el hash original que se firmó.

Finalmente, el receptor compara: **El hash calculado del documento recibido con el hash recuperado desde la firma. Si ambos coinciden, el sello es correcto y el documento es válido.** Si

no coinciden, significa que el documento ha sido alterado o bien que la firma no corresponde al emisor legítimo.

Ejemplos de uso común:

- Verificación de Certificados digitales.
- Facturas electrónicas.
- Contratos firmados electrónicamente.
- Trámites con administraciones públicas.
- Correos electrónicos firmados.
- Sellos de tiempo y validación documental.

4.4 Infraestructura PKI, certificados digitales y SSI

Aunque todo lo tocante se detallará en un próximo tema, sirva sólo este epígrafe de introducción.

Un certificado digital es un documento electrónico, firmado por una autoridad de confianza (AC o CA en inglés), que **vincula unos datos de verificación de firma (una clave pública) con una identidad** (persona física, jurídica, organismo o servidor).

Una PKI (Infraestructura de clave pública) es el conjunto de hardware, software, políticas y procedimientos necesarios para crear, gestionar, distribuir, usar, almacenar y revocar certificados digitales.

Su misión principal es establecer una relación de confianza **vinculando una clave pública con una identidad** (persona, organismo, servidor) de forma fehaciente.

En la actualidad, ha surgido con fuerza un nuevo concepto en el que se prescinde de la Autoridad de Confianza (FNMT, DGP etc.) pasando a un modelo de **Identidad Soberana Autogestionada** (Self Sovereign Identity o SSI en inglés).

En un modelo de SSI, el usuario utiliza un **Wallet** para custodiar sus claves, como por ejemplo hace Bitcoin.

El usuario, en vez de certificados digitales, utiliza un DID (Decentralized Identifier, Identificador Descentralizado): Una dirección URL única que apunta a un "Documento DID" alojado en una red descentralizada como puede ser una Blockchain o una DLT. Para más información se aconseja consultar con el tema dedicado a este tipo de arquitecturas.

Como resumen de este tema, recuerda que la principal diferencia entre el cifrado con clave pública y la firma digital es que:

- En el cifrado se usa la clave pública del destinatario y la clave privada del destinatario para recuperar el mensaje.
- En la firma digital se usa la clave privada del emisor para firmar y la clave pública del emisor para verificar.

La firma digital garantiza autenticidad, integridad y no repudio. Para firmar, el emisor calcula un hash del documento y lo cifra con su clave privada. Cualquiera puede verificar esa firma usando la clave pública del emisor. Recuerda también de cara a implementaciones, que en la actualidad se está prefiriendo el uso de la curva elíptica frente a RSA, a modo de transición a algoritmos PQC. De hecho y como curiosidad, la FNMT está migrando el uso de RSA de las tarjetas criptográfica a ECC.

También es preciso recordar que para verificar los documentos firmados se cuenta con VALIDE, donde la verificación del documento firmado digitalmente no es solo técnica, es un proceso de validación de confianza que sigue los estándares de la infraestructura de clave pública (PKI) española (contra @firma).

Para ampliar información se aconseja consultar el tema dedicado a las PKIs y también a los servicios comunes como @firma.

5 Comparativa entre criptografía simétrica y asimétrica

En la práctica real (como cuando se accede a una web de banca electrónica, no elegimos una u otra, sino que hacemos una mezcla de ambas. Se utiliza lo que llamamos **Criptografía Híbrida**:

- Se usa **Criptografía Asimétrica** (RSA/ECC) para intercambio de claves en Internet, por ejemplo, para que el navegador y el banco se "presenten" y acuerden una clave secreta de forma segura (Handshake).
- Se usa **Criptografía Simétrica** una vez acordada una clave para la sesión, pasan a usar Simétrica (AES) para el resto de la sesión porque es mucho más rápida.

5.1 Criptosistemas híbridos

A continuación, se presentan los criptosistemas híbridos de uso más común, estudiando cómo mezclan e implementan ambas criptografías.

5.1.1 TLS

TLS es el protocolo que implementa la seguridad sobre HTTP en Internet: Funciona en dos fases para que la comunicación sea eficiente:

- **Fase Asimétrica** (El "Apretón de manos" o Handshake): Se usan algoritmos como RSA o Curva Elíptica (ECDHE). El objetivo: Intercambiar de forma segura una "clave de sesión" secreta sin que nadie pueda interceptarla. Es lento pero muy seguro para establecer la conexión inicial.
- **Fase Simétrica** (La Transmisión de datos): Una vez que ambos tienen la clave de sesión, pasan a usar AES (normalmente AES-256). Objetivo: Cifrar el tráfico real (la web, las fotos, los datos). Es muchísimo más rápido y consume menos procesador que el cifrado asimétrico.

La recomendación actual de organismos como el CCN-CERT y el NIST es usar la versión TLS 1.3. No obstante, muchos clientes web y aplicaciones todavía no soportan TLS 1.3 a día de hoy. En cualquier caso, TLS 1.0 y 1.1 están totalmente depreciados y no deben usarse.

5.1.2 PGP / GPG

Cifrado de archivos y correos. Versión GNU (software libre) más usada: Kleopatra.

- **Parte Simétrica:** PGP genera una "clave de sesión" aleatoria y única para cifrar el archivo (usando **AES** o **CAST5**). Es muy rápido, incluso con archivos de varios GB.
- **Parte Asimétrica:** Esa clave de sesión se cifra con la **clave pública** del destinatario (usando **RSA** o **ElGamal**).
- **Resultado:** Solo el dueño de la clave privada puede descifrar la "llave" para luego abrir el archivo.

El CCN recomienda, para sistemas de difusión limitada el uso de una herramienta llamada EP880 con ciertas similitudes a Kleopatra certificada para nivel ALTO ENS y hasta difusión limitada, para cifrado de archivos y orientada a entornos oficiales y sensibles (difusión limitada).

5.1.3 S/MIME (Secure/Multipurpose Internet Mail Extensions)

Similar a PGP, pero integrado en estándares de correo corporativo.

- **Cifrado del mensaje** (confidencialidad): El contenido del correo se cifra usando la clave pública del destinatario.
- **Firma digital** (integridad y autenticación): Para asegurar que el mensaje no fue modificado y que proviene del remitente, el remitente firma digitalmente el hash del mensaje usando su clave privada.

Algunos clientes de correo ya lo incorporan de forma nativa. Otros precisan de la instalación de plugins para su uso.

5.1.4 WhatsApp / Signal

Protocolos de Mensajería.

Cuando envías un mensaje, no se usa cifrado asimétrico para cada palabra (sería lentísimo y agotaría la batería).

- **Fase Asimétrica:** Al instalar la app o iniciar un chat, se intercambian claves públicas mediante un protocolo llamado *Diffie-Hellman de triple etapa* (X3DH).
- **Fase Simétrica:** Una vez establecida la confianza, los mensajes individuales se cifran con **AES-256**. La clave simétrica cambia constantemente (Double Ratchet), pero la base sigue siendo una mezcla híbrida.

5.1.5 SSH (Secure Shell)

Es la herramienta que usan los administradores de sistemas para gestionar servidores de forma remota.

- **Paso 1 (Asimétrico):** El cliente y el servidor se autentican y acuerdan una clave secreta compartida mediante el algoritmo Diffie-Hellman.
- **Paso 2 (Simétrico):** Todo lo que se escribe en la terminal a partir de ahí viaja cifrado con algoritmos simétricos rápidos como ChaCha20 o AES.

5.1.6 IPsec (Internet Protocol Security) en modo túnel

Usado para VPNs y comunicaciones seguras a nivel de red.

Modo híbrido:

- Las claves de sesión se negocian mediante protocolos como IKE (Internet Key Exchange) usando criptografía asimétrica.
- El tráfico IP se cifra con algoritmos simétricos como AES o 3DES.

5.1.7 Cifrado de PDF y Office (con certificados)

Cuando protegemos un documento de Word o un PDF usando un certificado digital (en lugar de solo una contraseña):

- El software genera una clave de cifrado simétrica para el contenido del documento.
- Esa clave se protege (se envuelve) con la clave pública de las personas autorizadas para leerlo.

5.2 Comparativa

A continuación, haremos una comparativa entre criptografía simétrica y asimétrica. Comencemos primero por la equivalencia en la seguridad entre las claves y tipos de algoritmos usados:

Nivel de seguridad en bits	Algoritmo simétrico	Asimétrico (familia RSA)	Asimétrico (familia curva elíptica)	Comentario
80	AES-80	1024	160-223 bits	Obsoleto y no recomendado
112	Triple DES	2048		No recomendado, fuera de norma a finales de 2026
128	AES-128	3072	256-383 bits	Recomendado por el CCN usos comunes
192	AES-192	7680	384-511 bits	Recomendado por el CCN usos comunes, ENS nivel alto, datos más sensibles. La FNMT emite con la P-384 los certificados SSL OV
256	AES-256	15360 bits	512+ bits	Resistente Q-Attack.PQC

Tabla 5: Equivalencia de seguridad entre algoritmos simétricos y asimétricos

Como se puede apreciar, la criptografía simétrica ofrece mayor seguridad con menor longitud de claves. Sin embargo, en los algoritmos asimétricos son más seguros los de curva elíptica con menor longitud de clave que los de la familia RSA.

La siguiente tabla muestra una comparativa general entre la criptografía simétrica y asimétrica que también se ofrece a modo de resumen de este capítulo.

Característica	Criptografía Simétrica	Criptografía Asimétrica
Número de Claves	Una única clave compartida por emisor y receptor.	Un par de claves: una pública (se comparte) y una privada (se guarda).
Velocidad de ejecución	Muy rápida. Ideal para grandes volúmenes de datos.	Más lenta. Requiere mayor capacidad de procesamiento
Uso principal	Cifrado de archivos, discos duros y comunicaciones rápidas (AES).	Firma electrónica, intercambio seguro de claves y autenticación.
Gestión de las claves	Difícil: hay que enviar la clave al receptor de forma segura.	Fácil: la clave pública puede conocerla todo el mundo sin riesgo.
Seguridad cuántica	Resistente (solo requiere duplicar el tamaño de la clave actual para ajustarlo a la capacidad de ataque cuántico (Grover)).	Vulnerable (algoritmos como RSA o ECDSA caen ante Shor).
Algoritmos típicos	AES, ChaCha20	RSA, ECDSA
Algoritmos PQC	Los mismos anteriores con claves de 256 bits mínimo	Kyber (ML-KEM), Dilithium (ML-DSA)

Tabla 6: Comparativa entre criptografía simétrica y asimétrica

A modo de resumen de este capítulo recuerda que:

- **Criptografía Híbrida:** Combina la asimétrica (RSA/ECC) para el intercambio seguro de claves (Handshake) y la simétrica (AES) para el envío rápido de datos masivos.
- **Protocolos Estándar:** Implementa TLS 1.3 (web), SSH (administración remota), S/MIME/PGP (correo/archivos) y mensajería como WhatsApp/Signal.
- **Seguridad y Claves:** La simétrica es más eficiente (incluso con claves cortas), mientras que la asimétrica facilita la gestión al usar claves públicas que no requieren secreto previo.
- **Cumplimiento del ENS:** El CCN recomienda AES-128 (simétrica) vinculado a RSA-3072 o ECC-256 para nivel medio, y AES-256 para nivel alto y resistencia cuántica.
- **Vulnerabilidad Cuántica:** La asimétrica actual es vulnerable a Shor (requiere migrar a PQC), mientras que la simétrica resiste a Grover simplemente duplicando la clave.

6 El notariado y el sellado de tiempo

Aunque ya existe un tema que detalla todo lo relativo a la infraestructura de clave pública (en inglés PKI), así como los elementos que la componen y la firma digital en detalle, el notariado y el sellado de tiempo surgen como una necesidad asociada a la firma digital y la respuesta a las preguntas:

- **Validación de la identidad del firmante:** ¿Seguro que fue Bernardo y no un impostor quien firmó el documento que le entregó a Alicia? Esto ya hemos visto que con la firma digital se resuelve, pero no cualquier tipo de algoritmo es válido (esto se tratará en el tema correspondiente).
- **Capacidad y voluntad del firmante:** Esta verificación es imposible desde un punto de vista criptográfico per se, pero a menudo a nivel informático se requiere a través de algún mecanismo. Por ejemplo, marcar algún campo en la aplicación con la previsualización del documento, avisando de que se va a proceder a una operación de firma.
- **Momento en el que se firmó:** Información de suma importancia para evitar fraudes. Por ejemplo, sería fraudulento haber firmado el ok a una factura sin el contrato en curso, o rellenar la solicitud de vacaciones después de haberlas disfrutado.

6.1 Firma electrónica

Como ya se ha visto en el capítulo dedicado a criptografía asimétrica, la firma digital es un mecanismo criptográfico que **permite garantizar la autenticidad del origen, la integridad de los datos y, bajo determinadas condiciones, el no repudio**. Es importante destacar que, por sí sola, la firma digital no proporciona confidencialidad del contenido, siendo necesario recurrir a técnicas de cifrado cuando se requiera proteger la información frente a accesos no autorizados.

El no repudio y la autenticidad en un contexto práctico dependen no solo del algoritmo de firma, sino también del uso de infraestructuras de confianza, como los servicios de certificación y validación (por ejemplo, prestadores cualificados de servicios de confianza).

En este epígrafe y en el contexto de las garantías del uso de la firma digital para implementar la firma electrónica, es necesario diferenciar entre los conceptos de “firma digital” y “firma electrónica”.

La **Firma digital** es un concepto técnico como ya hemos visto. Se refiere a un valor generado mediante algoritmos criptográficos (habitualmente basados en criptografía de clave pública) a partir de unos datos y una clave privada. Este valor permite a un tercero verificar, mediante la clave pública correspondiente, que los datos no han sido alterados y que proceden del titular de la clave.

En la práctica moderna, las firmas digitales se implementan mediante estándares como RSA, ECDSA o EdDSA, y suelen aplicarse sobre un resumen (hash) de los datos en lugar del contenido completo

La **Firma electrónica** es un concepto jurídico. Hace referencia a cualquier conjunto de datos electrónicos utilizados por una persona para manifestar su voluntad de firmar.

El Reglamento (UE) nº 910/2014 (eIDAS) —y su evolución actual, el eIDAS 2.0— la define como:

“los datos en formato electrónico anejos a otros datos electrónicos o asociados de manera lógica con ellos que utiliza el firmante para firmar”.

Este marco normativo mantiene la clasificación de la firma electrónica en:

- **Firma electrónica simple** (o básica).
- **Firma electrónica avanzada:** Esta firma exige vinculación única al firmante y la identificación del mismo a través de ella así como el control exclusivo por parte del firmante de los datos de creación de firma y la detección de cualquier modificación de los datos firmados.

- **Firma electrónica cualificada:** Además de basarse en un certificado cualificado debe generarse mediante un dispositivo cualificado de creación de firma (por ejemplo el DNle), teniendo el efecto jurídico equivalente al de la firma manuscrita en toda la Unión Europea.

El reglamento eIDAS también establece que no se puede denegar validez jurídica a una firma electrónica por el mero hecho de no ser cualificada. Por tanto, mecanismos más simples (como un PIN, OTP o aceptación en una interfaz digital) pueden ser admitidos como firma electrónica, aunque con menor fuerza probatoria.

6.2 Sellado de tiempo

El sellado de tiempo (o timestamping) es el **mecanismo criptográfico que permite demostrar que un conjunto de datos existió en un momento determinado y que no ha sido alterado desde entonces.**

Técnicamente, **se basa en la unión de una función hash** (que identifica el documento) **con una fecha y hora proporcionada por una fuente de tiempo fiable.**

El resultado es un "sello" firmado digitalmente por una **Autoridad de Sellado de Tiempo (TSA)**, lo que vincula de forma indisoluble el contenido con el instante cronológico de su creación o presentación.

Su importancia jurídica radica en la creación de una "fecha cierta" electrónica, superando la vulnerabilidad de los relojes locales de los ordenadores, que pueden ser manipulados fácilmente.

En el ámbito del Notariado, el sellado de tiempo actúa como la evolución digital del acta de presencia: **el notario, como tercero de confianza cualificado, garantiza mediante este proceso la integridad cronológica de los documentos en su protocolo, asegurando que un archivo digital existía exactamente en el momento de su autorización y otorgándole plena eficacia frente a terceros.**

La importancia es de suma importancia y como se verá en siguientes temas, incluso aunque el propio usuario cambie de certificado con posterioridad.

El sello de tiempo simple es aquel que asocia unos datos electrónicos con un instante concreto, pero carece de garantías legales automáticas sobre la precisión de su fuente de tiempo o la identidad de quien lo emite. Por el contrario, **el sello de tiempo cualificado** debe cumplir con los estrictos requisitos del Reglamento (UE) 910/2014 (eIDAS) que regula la firma electrónica y los servicios digitales de confianza. Esta normativa se ampliará en el tema de firma electrónica.

6.3 Notario digital TSA

Frente a la seguridad técnica que ofrecen el cifrado y las funciones hash, el Notariado digital (TSA) ofrece la seguridad jurídica que se precisa, ya que garantiza que todo el proceso de firma se ha realizado conforme a la legalidad.

Este proceso asegura que el emisor no tiene que enviar el documento real a la autoridad, manteniendo **la confidencialidad del documento que se envía a la TSA:**

El proceso de generación es como sigue:

- **Generación del Hash:** El usuario (o el sistema empleado) aplica un algoritmo hash (ej. SHA-256) al documento original para obtener su "huella digital" única.
- **Envío de la Solicitud:** Se envía únicamente el hash a la TSA.
- **Agregación de la Fecha:** La TSA recibe el hash y le añade la fecha y hora exacta proveniente de una fuente de tiempo atómica y sincronizada (UTC).
- **Firma del Sello:** La TSA firma digitalmente el conjunto (Hash + Tiempo) con su propia clave privada.
- **Entrega del Token:** La TSA devuelve al usuario un "Token de Tiempo" (fichero con extensión *.tsr*) que se adjunta al documento original.

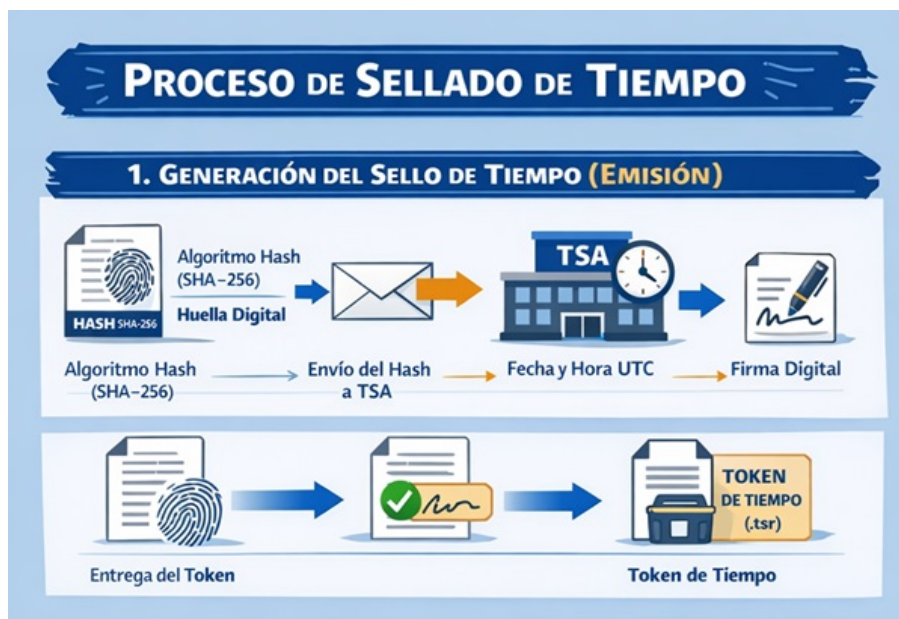


Figura 9: Generación del sello de tiempo

Para verificar el documento, cualquier tercero, como un juez, un notario u otra administración, puede **verificar la validez del sello siguiendo estos pasos:**

- **Cálculo del Hash actual:** El verificador toma el documento original y le vuelve a aplicar el mismo algoritmo hash.
- **Extracción del Hash sellado:** Abre el Token de Tiempo y extrae el hash que la TSA certificó en su momento.
- **Comparación de Huellas:**
 1. Si los hashes coinciden, se garantiza que el documento no ha sido alterado desde el momento del sellado (Integridad). Se pasa al último paso, validación de la autoridad.
 2. Si no coinciden, el sello queda invalidado.
- **Validación de la Autoridad:** Se verifica la firma electrónica de la TSA usando su clave pública. Si la firma es válida y el certificado de la TSA estaba vigente en ese momento, se confirma la "fecha cierta" del documento.

Como resumen y complemento de este capítulo es importante recordar lo siguiente:

- **Firma Digital vs. Firma Electrónica.** La Firma Digital (Concepto Técnico) es el proceso criptográfico (hash + clave privada) que garantiza integridad y autenticidad. No ofrece confidencialidad por sí misma. La Firma Electrónica (Concepto Jurídico) es la manifestación de voluntad en formato electrónico. Según eIDAS, se clasifica en Simple, Avanzada (vinculación única y control exclusivo) y Cualificada (basada en certificado y dispositivo cualificado, como el DNLe, con equivalencia legal a la firma manuscrita).
- **Capacidad y Voluntad del Firmante:** La criptografía por sí sola no puede asegurar que el firmante "quiso" firmar o tenía capacidad legal en ese momento. Para mitigar esto, los sistemas informáticos deben implementar mecanismos de previsualización y advertencia antes de ejecutar la operación de firma, reforzando así la validez jurídica del acto.
- **Sellado de Tiempo (Timestamping):** Es el mecanismo que otorga "fecha cierta" a un documento, evitando fraudes cronológicos (como firmar tras el vencimiento de un contrato).

7 Criptoanálisis, matemáticas y eficiencia computacional

Por no abarrotar de detalles en los capítulos anteriores, se ofrece este capítulo a modo de información complementaria pero útil de cara a la implementación práctica.

7.1 Criptoanálisis

El criptoanálisis se basa en el estudio de los sistemas de cifrado para encontrar debilidades y descifrar información sin poseer la clave. Dado que la robustez de la criptografía depende del fracaso de las técnicas de criptoanálisis, daremos una breve pincelada de dichas técnicas:

- **Análisis de frecuencias:** Se usa sobre todo contra cifrados clásicos (como el de sustitución). Consiste en estudiar qué letras aparecen más veces en el texto cifrado y compararlas con la frecuencia típica del idioma (por ejemplo, en español la “e” es muy común). A partir de ahí se deducen posibles correspondencias entre letras cifradas y reales.
- **Ataque de texto conocido (Known-plaintext attack):** Aquí el atacante ya conoce una parte del mensaje original y su versión cifrada. Con esa información intenta descubrir la clave o el método de cifrado para poder descifrar otros mensajes.
- **Ataque de texto elegido (Chosen-plaintext attack):** En el caso de que el atacante pueda elegir mensajes y obtener sus versiones cifradas, permite analizar cómo responde el sistema a entradas específicas y facilita encontrar patrones o vulnerabilidades. Viene a ser como una ingeniería inversa aplicada a la criptografía.
- **Ataque de clave elegida (Chosen-key attack):** Menos común. El atacante analiza cómo el sistema se comporta con diferentes claves para encontrar debilidades en el algoritmo.
- **Criptoanálisis diferencial:** Muy usado contra cifrados modernos (como bloques tipo AES). Analiza cómo pequeñas diferencias en el texto original afectan al texto cifrado, buscando patrones que revelen información sobre la clave.
- **Criptoanálisis diferencial:** Intenta aproximar el comportamiento del cifrado mediante relaciones lineales entre bits del texto plano, cifrado y la clave.
- **Ataque de texto cifrado (Ciphertext-only attack):** Es el escenario más limitado: solo se tiene acceso al texto cifrado. Se basa en estadísticas, patrones y suposiciones sobre el idioma o el contenido.
- **Ataque por fuerza bruta:** Probar todas las combinaciones posibles. Esto cada vez es más factible con la computación cuántica.
- **Ataque por canal lateral:** Ataques a criptosistemas implementados en hardware principalmente examinando características particulares como el consumo de energía o el tiempo de respuesta.

7.2 Fundamentos matemáticos

La criptografía se basa en matemáticas. Sirva sólo este epígrafe como pincelada para entender los algoritmos ya vistos a lo largo del tema.

- **Aritmética modular:** Aplica tanto a la criptografía clásica (cifrados monoalfabéticos y polialfabéticos) como a algoritmos más actuales como RSA, Diffie-Hellman y curvas elípticas.
- **Factorización de números primos:** Son esenciales porque ciertos problemas relacionados con factores primos son difíciles de resolver. La seguridad de RSA depende de que el criptoanálisis implica factorizar números muy grandes lo cual es computacionalmente costoso.
- **Funciones hash:** Utilizan aritmética modular, transformando mensajes de longitud variables en varios bloques del tamaño que puede procesar. Por ejemplo, SHA256 utiliza bloques de 512bits. Si el mensaje no contiene un múltiplo de 512bits, lo rellena con una cadena de 1s y 0s (padding). El núcleo del algoritmo consiste en un estado interno de 256 bits (dividido en ocho registros de 32 bits) que se somete a 64 rondas de transformación mediante operaciones no lineales, rotaciones bit a bit (SHR, ROTR) y funciones lógicas (Ch, Maj), utilizando constantes derivadas de números primos. El resultado final es un digest determinista de 32 bytes (256bits), representado usualmente como una cadena de 64 caracteres hexadecimales, que garantiza resistencia a preimagen y colisiones.

- **Álgebra lineal:** Se usa en algunos cifrados clásicos y en ciertos esquemas modernos de criptografía post-cuántica, especialmente los basados en retículas. También se usa en criptografía homomórfica. Si en la criptografía tradicional se utiliza mucho la teoría de números (primos, módulos), en la homomórfica se opera con los retículos (lattices) y las operaciones con matrices y vectores.
- **Teoría de grupos y cuerpos finitos (Galois):** permite definir estructuras matemáticas sobre las que operan muchos algoritmos criptográficos. Es clave en Diffie-Hellman y en la criptografía de curvas elípticas.
- **Curvas elípticas:** proporcionan gran seguridad con claves más pequeñas. Se usan en firmas digitales y cifrado moderno, como ECDSA.
- **Probabilidad y estadística:** fundamentales en criptoanálisis para detectar patrones, medir aleatoriedad y evaluar la fortaleza de claves, contraseñas o generadores de números aleatorios.
- **Logaritmo discreto:** problema matemático difícil sobre el que se basan muchos sistemas de intercambio de claves y firmas digitales.
- **Combinatoria:** ayuda a calcular el número de posibles claves y la resistencia frente a ataques de fuerza bruta.
- **Retículos (lattices):** son estructuras geométricas formadas por puntos distribuidos regularmente en espacios multidimensionales. La seguridad de mucha criptografía post-cuántica se basa en problemas difíciles sobre retículos, como el SVP (Shortest Vector Problem), el CVP (Closest Vector Problem), y el LWE (Learning With Errors)
- **Teoría de la información:** permite analizar cuánta información revela un sistema y cuánto secreto conserva frente a un atacante.

7.3 Eficiencia computacional

La **complejidad computacional** estudia cuánto tiempo y recursos se necesita para resolver un problema. La criptografía busca problemas fáciles de calcular, pero difíciles de romper, como la factorización de números primos o el logaritmo discreto. Hay que tener en cuenta que el criptoanálisis también aplica matemáticas para intentar romper cifrados, encontrar debilidades, reducir el espacio de búsqueda o explotar errores de implementación, ya que a veces protocolos o aplicaciones que implementan criptografía no siempre lo hacen de forma correcta.

En criptografía simétrica, algoritmos como DES y AES tienen una complejidad de cifrado aproximadamente lineal respecto al tamaño del bloque o del mensaje, es decir, $O(n)$, porque procesan cada bloque mediante rondas fijas de sustitución y permutación. Sin embargo, la seguridad real depende del tamaño de la clave, de ahí que DES esté desaconsejado.

En criptografía asimétrica, la complejidad depende de problemas matemáticos difíciles. RSA basa su seguridad en la factorización de enteros grandes. Las operaciones normales de cifrado y firma usan exponenciación modular, con coste aproximado logarítmico, pero romper RSA mediante los mejores algoritmos clásicos de factorización, como tiene una complejidad subexponencial.

En cambio, la criptografía de curva elíptica utiliza el problema del logaritmo discreto sobre curvas elípticas. Por eso una clave ECC de 256 bits suele ofrecer una seguridad comparable a RSA de 3072 bits: romperla exige aproximadamente 2^{128} operaciones.

La futura criptografía post-cuántica intenta resistir algoritmos cuánticos como el de Shor, que podría romper RSA y ECC en tiempo polinómico si existieran ordenadores cuánticos suficientemente grandes.

Por ello, algoritmos como Kyber y Dilithium se basan en problemas de retículos, para los cuales no se conocen ataques clásicos ni cuánticos eficientes.

Tipo	Algoritmo	Complejidad	Dependencia
Simétrico	AES, ChaCha20	$O(n)$	tamaño del mensaje
Asimétrico	RSA	$O(k^2 - k^3)$	tamaño de clave
Asimétrico	ECC	$O(k^2)$	tamaño de clave
Hash	SHA-256	$O(n)$	tamaño del mensaje

Tabla 7: Complejidad de algoritmos

7.4 Métricas para implementación

Después de toda la información contenida en este tema, llega el momento de ponerla en práctica abordando un proyecto de ingeniería. Es preciso realizar la recomendación de qué algoritmos y protocolos con uso de criptografía se deben utilizar.

Toda vez que la normativa y seguridad adecuada (ENS) se ha analizado, para algoritmos candidatos se deben tener en cuenta las siguientes métricas de la idoneidad del sistema:

- **Throughput (Gbps):** ¿Cuántos datos por segundo es capaz de procesar nuestro algoritmo?
- **¿Debemos abordar una implementación en Hardware?** Si el algoritmo debe ir embarcado o embebido (como los chips del DNI por ejemplo) o en un cifrador hardware, HSM o equipo similar (FPGA), entonces se deben analizar los pros y contras y software adicional a incorporar. Por ejemplo, en implementaciones en hardware a menudo se deben actualizar los drivers del sistema. O es preciso valorar si el usuario final precisa instalar nuevos dispositivos: Por ejemplo, cuando surgió el DNI electrónico casi nadie tenía un lector incorporado en el PC.
- **¿Qué energía eléctrica va a consumir?** Es importante sobre todo de cara a dispositivos IoT. De hecho, existe una rama de la criptografía dedicada a ellos (Criptografía ligera).
- **Latencia:** ¿Cuánto tarda en aparecer el primer bit cifrado?

Como resumen de este capítulo recuerda que:

- **Criptanálisis:** Se basa en explotar debilidades mediante estadística (frecuencias), patrones (diferencial/lineal) o hardware (canales laterales), además de la fuerza bruta. Es importante para medir la robustez de los algoritmos y protocolos a utilizar.
- **Fundamentos matemáticos que usa la criptografía:** Utiliza aritmética modular, factorización de primos (RSA), logaritmo discreto (ECC) y retículos (PQC) para crear problemas difíciles de resolver, resistentes al criptoanálisis.
- **Complejidad:** Los algoritmos simétricos y hashes son rápidos (lineales $O(n)$), mientras que los asimétricos son más costosos por su base matemática.
- **Eficiencia:** La Curva Elíptica (ECC) es superior a RSA al ofrecer el mismo nivel de seguridad con claves mucho más pequeñas y menor consumo.
- **Métricas:** En implementaciones de sistemas se debe balancear el *throughput* (velocidad), la latencia y el soporte hardware (HSM para servidores o chips como el del DNIe para usuarios).
- **ENS:** Debes asegurarte de que aplicas los algoritmos, protocolos, mecanismos y hardware recomendado por el CCN para el nivel de categorización del sistema. Consulta las guías (en la bibliografía están las obligatorias).

8 Tendencias a futuro de la Criptografía

La criptografía enfrenta desafíos técnicos y sociales de gran calado. Estos desafíos están suponiendo un esfuerzo enorme para las organizaciones. A continuación, se enumeran los restos principales.

8.1 Criptografía PQC

La criptografía tal y como se usa actualmente es **vulnerable a ataques cuánticos**, mediante la aplicación de dos algoritmos que son eficaces en ordenadores cuánticos de capacidades suficientes (hoy en día no existen pero se está en la senda de conseguirlo en los años venideros).

El **algoritmo de Shor** utiliza la Transformada Cuántica de Fourier para explotar la estructura matemática (periodicidad) de la asimétrica, permitiendo resolver el problema de fondo. El **algoritmo de Grover** sirve para mejorar estadísticamente la búsqueda, lo que simplemente acelera la fuerza bruta sobre claves simétricas y hashes.

La adopción de la criptografía PQC sin embargo, es un reto de suma complejidad. Para analizar el nivel de riesgo al que se enfrentan los sistemas, se debe aplicar la **ecuación de Mosca**:

Estamos en grave riesgo si $D + X > Y$, donde D es el tiempo de vida de los secretos, X es el tiempo para migrar a PQC e Y el tiempo de colapso (lo que falta para que llegue el Q-Day).

Como Y es desconocido, el problema es balancear lo que tardaremos en migrar contra el tiempo que necesitamos que nuestros datos permanezcan secretos. Así por ejemplo si vamos a tardar en migrar más de cuatro años, y necesitamos tener nuestros datos cifrados más de dos años, como el Q-Day llegue antes de seis años, tendremos un problema serio.

La solución de compromiso que muchas organizaciones están adoptando ya es la de la **Criptografía Híbrida Post-Cuántica** (también conocida como esquemas de transición o "Hybrid Post-Quantum"). Estos esquemas aplican simultáneamente dos algoritmos sobre los mismos datos: Un algoritmo precuántico como RSA por ejemplo y otro postcuántico sobre lo anterior. El problema sin embargo, es los protocolos de comunicación soportan a duras penas estos datos cifrados de esta manera.

8.2 Criptoagilidad y secretos efímeros

La **criptoagilidad** es la **capacidad de un sistema, software o infraestructura para cambiar rápidamente sus algoritmos criptográficos, protocolos o claves sin interrumpir las operaciones ni requerir modificaciones significativas en su arquitectura**. Se trata de ser ágil y poder cambiar rápidamente cuando se demuestre que algún componente puede ser vulnerable.

El punto de partida y la primera recomendación es la de mantener un inventario de activos criptográficos, pues no se puede proteger lo que no se conoce. Este inventario debe contener:

- **Certificados Digitales:** Fecha de caducidad, autoridad certificadora (CA), algoritmos de firma y propósito (sede electrónica, firma de empleados, cifrado de servidores).
- **Claves Privadas:** Ubicación (¿están en un HSM, en un token software, en el almacén de Windows?), nivel de protección y responsables.
- **Algoritmos y Protocolos:** Qué versiones de TLS, SSH o IPsec están activas en cada servicio de la Administración.
- **Hardware Criptográfico:** HSM (Hardware Security Modules), tarjetas inteligentes y lectores de DNle y SmartCards.

Para gestionar el inventario se pueden utilizar herramientas Certificate Management System (CMS) o herramientas de gestión de claves (KMS). Estas herramientas permiten detectar, inventariar y operar los activos antes mencionados.

Algunas medidas en Internet para minimizar los riesgos antes el Q-Day se basan en acortar la duración de los certificados digitales. En esta línea se encuentran tanto la normativa europea de referencia (eIDAS2) y las normas ETSI, como el foro que aglutina los gigantes de tecnología en el ciberespacio denominado **CA/Browser Forum (CA/B Forum)** y que establece las recomendaciones criptográficas globales.

El **secreto efímero** aparece descrito en la novela de culto Criptonomicón con la cita de su protagonista: *"En el mundo real, nadie cifra nada para que sea indescifrable por siempre. Solo se precisa que sea indescifrable durante el tiempo suficiente."* De este modo, la tendencia es a acortar el tiempo de vida de las claves y de los secretos restringiéndolos estrictamente a su consumo puntual.

8.3 Criptografía homomórfica

Otro gran reto es el de la operación segura de la información en la Nube. De este modo surge la **Criptografía Homomórfica**, que consiste en **gestionar datos cifrados y obtener el equivalente a operarlos en claro y luego cifrarlos**.

De este modo, se preserva la confidencialidad de los datos cuando los gestionan terceros. El reto es conseguir que sea eficiente computacionalmente para poder operar con los datos sin necesidad de descifrarlos nunca, manteniendo la privacidad total en la Nube. La siguiente ilustración es una infografía sobre los tipos de cifrado homomórfico que existen en la actualidad.

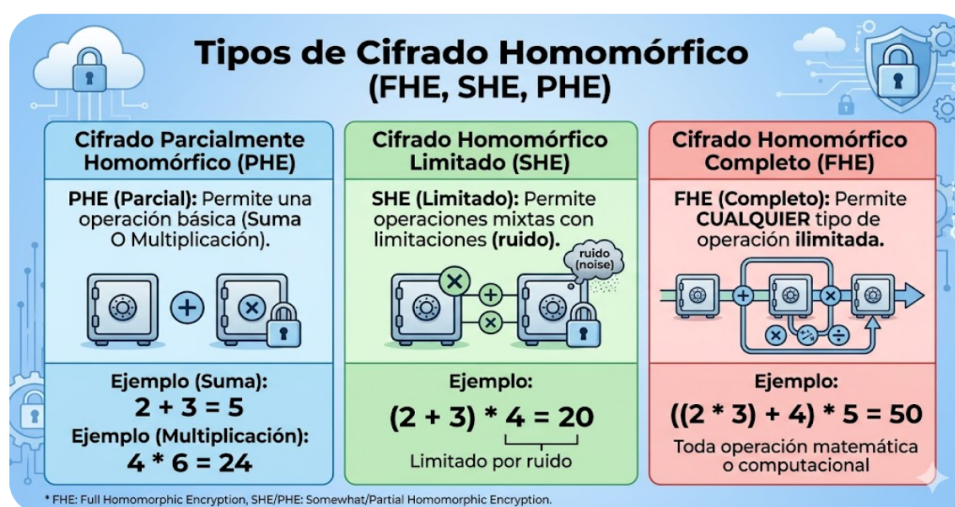


Figura 10: Tipos de cifrado homomórfico

8.4 Criptografía de gestión de la identidad

Con el auge de blockchain, la identidad soberana y las carteras digitales, el reto es cómo gestionar claves privadas de forma segura para el usuario medio sin depender de una autoridad central que pueda recuperarlas esto es: **gestión de la identidad en entornos descentralizados**. En el capítulo 5 ya se ha comentado el auge de estos sistemas de SSI y las carteras digitales.

Para poder implementarla se recurre al modelo de **evaluación de atributos** (attribute assesment), de modo que el usuario expone parte de su identidad (atributos), y el verificador comprueba dichos atributos sin acceder a la identidad completa del usuario, mediante el uso de **Pruebas de Conocimiento Zero (ZKP)**, que recaen en **desafíos criptográficos**.

El diseño de estos desafíos criptográficos supone realmente un reto para los criptólogos, pues un fallo en los mismos expone la privacidad del usuario.

Recuerda: **debemos abordar desde ya la preparación ante la amenaza cuántica**, aplicar la Ecuación de Mosca para **evaluar el riesgo y la necesidad de migrar a algoritmos PQC** mediante un **enfoque de cryptoagilidad**, basado en la **gestión de activos criptográficos** y **reduciendo el tiempo de vida de los secretos** para limitar el impacto de un posible compromiso.

Además, debemos **avanzar en la privacidad**: La criptografía homomórfica permite procesar datos en la nube sin descifrarlos, mientras que las ZKP (Zero-Knowledge Proofs) permiten verificar atributos de identidad sin revelar datos personales.

9 RESUMEN ESQUEMÁTICO

- La criptografía es la rama de la criptología que se encarga del diseño y la aplicación de técnicas y algoritmos destinados a cifrar y proteger la información, garantizando su confidencialidad, integridad y autenticidad.
- La criptología es la ciencia que estudia la comunicación oculta y segura; se divide en dos grandes disciplinas: la criptografía y el criptoanálisis, que busca descifrar y encontrar vulnerabilidades en dichos métodos.
- Cifrar consiste en transformar información legible en ilegible mediante un algoritmo y una clave, mientras que codificar simplemente establece equivalencias entre símbolos de un alfabeto como sucede con ASCII.
- Un criptosistema consta de un algoritmo y una clave, y en función de dicho algoritmo y clave se asigna a un texto en claro un texto cifrado.
- La criptografía clásica se basaba en métodos manuales o mecánicos, principalmente sustitución y transposición de letras. Ejemplos famosos son el cifrado César y la máquina Enigma.
- La criptografía moderna sustituyó las letras por bits y bytes, y pasó de operaciones simples a matemáticas más complejas como XOR, cuerpos de Galois, factorización de números primos y curvas elípticas. Además, los algoritmos dejaron de ser secretos y pasaron a ser públicos y revisados por expertos, lo que aumentó enormemente su seguridad.
- La criptografía simétrica utiliza una sola clave compartida entre emisor y receptor para cifrar y descifrar. Es muy rápida y eficiente, por lo que se usa para proteger grandes cantidades de datos. Existen cifrados de flujo, como ChaCha20, y cifrados de bloque, como AES, que trabajan con bloques de tamaño fijo.
- Los algoritmos simétricos pueden ser de flujo o de bloque. En los de flujo, el mensaje se combina mediante XOR con una clave generada de forma pseudoaleatoria. En los de bloque, el mensaje se trocea en bloques a los que se le aplican operaciones de permutación y trasposición fundamentalmente.
- AES es el estándar actual de cifrado simétrico. Utiliza bloques de 128 bits y claves de 128, 192 o 256 bits. Su funcionamiento se basa en varias rondas de operaciones matemáticas sobre bloques. AES destaca por su rapidez y seguridad, por lo que es el más usado.
- Las funciones hash permiten comprobar la integridad de los datos. Algoritmos como SHA-256 generan un resumen único del contenido, de forma que un pequeño cambio en el mensaje produce un hash completamente distinto. Las propiedades más importantes de un hash son ser determinista, irreversible, resistente a colisiones y producir efecto avalancha.
- La criptografía asimétrica utiliza un par de claves: una pública y otra privada. Permite resolver el problema de la distribución segura de claves y se usa para cifrado, firma digital e identificación. RSA se basa en la dificultad de factorizar números primos grandes, mientras que ECC ofrece una seguridad similar con claves mucho más pequeñas. En la práctica, Internet usa criptografía híbrida: asimétrica para intercambiar claves y simétrica para proteger el resto de la comunicación.
- La firma digital garantiza autenticidad, integridad y no repudio. Para firmar, el emisor calcula un hash del documento y lo cifra con su clave privada. Cualquiera puede verificar esa firma usando la clave pública del emisor.
- La firma electrónica es un concepto jurídico basado en tecnología de firma digital.
- El sellado de tiempo añade una prueba de cuándo existía un documento concreto firmado, ubicándolo con una fecha y hora certificada por una Autoridad de Sellado de Tiempo (TSA).
- El futuro de la criptografía está marcado por la amenaza de la computación cuántica frente a la que se erige la PQC. Además, se están impulsando conceptos como criptoagilidad, criptografía híbrida, criptografía homomórfica y pruebas de conocimiento cero para probar atributos de la identidad sin perder privacidad.

10 GLOSARIO

- **AES (Advanced Encryption Standard):** Estándar de cifrado avanzado basado en el algoritmo Rijndael, seleccionado por el NIST en el año 2000 para reemplazar a DES.
- **Autenticación:** Proceso que permite confirmar la identidad de un emisor o receptor en una comunicación.
- **Block Cipher (Cifrado de Bloque):** Algoritmo que procesa la información en grupos de bits de tamaño fijo (como 64 o 128 bits).
- **Bootstrapping:** Técnica en el cifrado homomórfico completo (FHE) que permite "limpiar" el ruido acumulado para seguir operando indefinidamente.
- **Brute Force (Fuerza Bruta):** Ataque que consiste en probar todas las combinaciones posibles de claves hasta encontrar la correcta.
- **Criptografía Asimétrica (Clave Pública):** Sistema que utiliza un par de claves: una pública para cifrar y una privada para descifrar.
- **Criptografía Híbrida (Sobre Digital):** Combinación de cifrado simétrico (para los datos) y asimétrico (para proteger la clave simétrica).
- **Criptografía Simétrica (Clave Privada):** Sistema donde emisor y receptor comparten una única clave secreta para cifrar y descifrar.
- **Criptanálisis:** Ciencia que estudia los sistemas criptográficos para encontrar debilidades y romper algoritmos sin conocer la clave.
- **Criptanálisis Diferencial:** Técnica que analiza cómo las variaciones en los datos de entrada afectan a los datos de salida cifrados.
- **Criptanálisis Lineal:** Método que busca relaciones lineales entre el texto en claro, el texto cifrado y la clave.
- **CSV (Código Seguro de Verificación):** Aplicación práctica de códigos de autenticación (MAC) en la administración pública.
- **Confidencialidad:** Garantía de que solo las personas autorizadas pueden acceder a la información.
- **Confusión:** Técnica de diseño que hace que la relación entre la clave y el texto cifrado sea lo más compleja posible.
- **Colisión:** En funciones hash, cuando dos mensajes diferentes producen exactamente el mismo resumen o huella digital.
- **DES (Data Encryption Standard):** Estándar oficial de cifrado simétrico adoptado en 1976 que utiliza bloques de 64 bits y claves efectivas de 56 bits. Desaconsejado en la actualidad.
- **Difusión:** Técnica que busca expandir la influencia de un solo bit del texto claro sobre muchos bits del texto cifrado para evitar patrones estadísticos.
- **Diffie-Hellman:** Protocolo de criptografía que permite a dos partes generar una clave compartida secreta a través de un canal de comunicación público e inseguro.
- **DSA (Digital Signature Algorithm):** Algoritmo de firma digital basado en el problema del logaritmo discreto.
- **ECC (Elliptic Curve Cryptography):** Criptografía de curva elíptica, que permite claves más cortas con una seguridad equivalente a otros sistemas.
- **ECC (Elliptic Curve Cryptography):** Criptografía de curva elíptica; ofrece la misma seguridad que otros sistemas, pero con claves mucho más cortas.
- **ElGamal:** Algoritmo de criptografía asimétrica basado en el problema matemático del logaritmo discreto. Se utiliza tanto para el cifrado de datos como para la creación de firmas digitales.
- **FHE (Full Homomorphic Encryption):** Cifrado homomórfico completo que permite realizar cualquier operación de forma ilimitada (contexto de estudios previos).

- **Firma Digital:** Valor criptográfico que asegura la integridad, la identidad del autor y el no repudio de un documento.
- **Firma Electrónica:** Los datos en formato electrónico anejos a otros datos electrónicos o asociados de manera lógica con ellos que utiliza el firmante para firma
- **FIPS (Federal Information Processing Standards):** Estándares de seguridad del gobierno de EE. UU. (como FIPS 197 para AES).
- **Función Hash:** Algoritmo unidireccional que genera una huella de tamaño fijo a partir de un mensaje de cualquier longitud.
- **Integridad:** Propiedad que asegura que la información no ha sido modificada por terceros no autorizados.
- **Kyber (CRYSTALS-Kyber):** Algoritmo de criptografía post-cuántica utilizado para el intercambio seguro de claves. Es la propuesta resistente a ataques frente al Diffie-Hellman.
- **MAC (Message Authentication Code):** Funciones hash que utilizan una clave compartida para garantizar tanto la integridad como la autenticidad del origen.
- **MDC (Modification Detection Codes):** Códigos utilizados exclusivamente para la verificación de la integridad de los mensajes. NIST (National Institute of Standards and Technology): Organismo estadounidense que convoca concursos y publica estándares criptográficos como AES y SHA-3.
- **MD5:** Función hash criptográfica de 128 bits diseñada por Ronald Rivest en 1991. Desaconsejada en la actualidad.
- **Meet-in-the-middle Attack:** Ataque que reduce la seguridad efectiva de algoritmos con múltiples cifrados (como el Triple-DES).
- **No Repudio:** Garantía de que alguien no puede negar haber enviado o firmado un mensaje o documento.
- **Padding (Relleno):** Bits adicionales que se añaden al final de un mensaje para que encaje exactamente en los bloques del algoritmo.
- **Plaintext Attack (Ataque de texto en claro):** Ataque donde el criptoanalista conoce parte del mensaje original y su correspondiente versión cifrada.
- **PKI (Public Key Infrastructure):** Infraestructura de clave pública que utiliza certificados digitales para gestionar y garantizar la confianza en las identidades.
- **Prueba de conocimiento cero (ZKP):** Protocolo criptográfico que establece un método para que una de las partes pruebe a otra que una declaración (generalmente matemática) es cierta, sin revelar nada más que la veracidad de la declaración.
- **Resistencia a la pre-imagen:** Propiedad de un hash que impide deducir el mensaje original a partir del resumen resultante.
- **RSA (Rivest, Shamir, Adleman):** Algoritmo asimétrico basado en la dificultad de la factorización de números enteros grandes.
- **SHA (Secure Hash Algorithm):** Familia de funciones hash creadas por la NSA; incluye versiones como SHA-1 (inseguro), SHA-2 y SHA-3.
- **SSI (Self Sovereign Identity):** Modelo de identidad digital que devuelve al usuario el control exclusivo sobre sus datos personales, permitiéndole almacenarlos, gestionarlos y compartirlos sin depender de autoridades centrales o proveedores de servicios intermediarios. Ejemplo Bitcoin.
- **Stream Cipher (Cifrado de Flujo):** Algoritmo que cifra la información bit a bit o byte a byte en tiempo real.
- **TDES (Triple DES):** Variante de DES que aplica el algoritmo tres veces para aumentar la seguridad, con una longitud de clave efectiva de 112 bits.

11 TEST

11.1 PREGUNTAS DE TEST

- 1) **¿Qué tipo de ataque (criptoanálisis) permite romper los cifrados monoalfabéticos?**
 - a) Ataques cuánticos
 - b) Análisis de frecuencias
 - c) Colisiones
 - d) Factorización de números primos
- 2) **¿Qué problema resolvió por primera vez la criptografía asimétrica?**
 - a) La compresión de mensajes
 - b) La factorización de números primos
 - c) El análisis de frecuencias
 - d) La distribución segura de claves
- 3) **¿Cuál de los siguientes algoritmos está actualmente desaconsejado por su inseguridad?**
 - a) ChaCha20
 - b) AES-GCM
 - c) RC4
 - d) SNOW 3G
- 4) **¿Qué operación lógica es fundamental para los cifradores de flujo?**
 - a) OR
 - b) XOR
 - c) NAND
 - d) AND
- 5) **Si estamos cifrando con cifrado César de clave 3, la letra “a” se cifraría como:**
 - a) A
 - b) 4
 - c) d
 - d) a'
- 6) **¿Qué modo de operación de cifrado en bloque es inseguro porque bloques iguales producen salidas iguales?**
 - a) ECB
 - b) CBC
 - c) GCM
 - d) CTR
- 7) **¿Cuál es la principal utilidad de una función hash?**
 - a) Cifrar mensajes largos y producir una salida más pequeña
 - b) Reducir el tamaño de los archivos
 - c) Intercambiar claves
 - d) Determinar si un archivo ha sido alterado
- 8) **¿Qué se utiliza en una firma digital para firmar un documento?**
 - a) La clave pública del receptor
 - b) La clave privada del emisor
 - c) La clave simétrica compartida
 - d) El hash del destinatario

- 9) **¿De qué depende principalmente la seguridad de RSA?**
- a) Del análisis de frecuencias
 - b) Del problema matemático de la factorización de números primos grandes
 - c) Del logaritmo discreto
 - d) De los retículos
- 10) **¿Qué tipo de ataque (criptoanálisis) permite romper los cifrados monoalfabéticos?**
- a) Ataques cuánticos
 - b) Análisis de frecuencias
 - c) Colisiones
 - d) Factorización de números primos
- 11) **Las pruebas de conocimiento cero son útiles para:**
- a) Agregar rondas al algoritmo AES
 - b) Cifrado homomórfico
 - c) Cifrado en flujo
 - d) Probar atributos en criptografía aplicada a la identidad
- 12) **¿Qué tipo de ataque no explota el algoritmo sino fugas físicas como consumo eléctrico o tiempo de respuesta??**
- a) Ataque de canal lateral
 - b) Ataque en texto plano
 - c) Ataque por fuerza bruta
 - d) Análisis de frecuencias
- 13) **En criptografía de clave pública, indica la respuesta cierta:**
- a) Ciframos el mensaje con la clave pública del destinatario y firmamos con nuestra clave privada de firma.
 - b) Ciframos el mensaje con nuestra clave privada y firmamos con nuestra clave privada de firma.
 - c) Ciframos el mensaje con la clave pública del destinatario y firmamos con nuestra clave pública de firma.
 - d) Ciframos el mensaje con la clave privada del destinatario y firmamos con nuestra clave pública de firma.
- 14) **¿Qué ventaja ofrece la criptografía de curva elíptica frente a RSA?**
- a) Emplea retículos como base matemática
 - b) Está avalada por la NASA
 - c) Ofrece la misma seguridad con claves más pequeñas
 - d) Es resistente a ataques cuánticos mientras que RSA no
- 15) **¿Qué es Kleopatra?**
- a) Un protocolo de red criptográfico que permite a los usuarios acceder y gestionar ordenadores de forma remota de manera segura
 - b) Uno de los primeros sistemas de criptografía de transposición, utilizado por los egipcios hace 4000 años
 - c) Un software de cifrado para criptografía homomórfica
 - d) Un software de cifrado y gestor de certificados de código abierto
- 16) **¿Qué amenaza representa el algoritmo cuántico de Shor?**
- a) Romper MD5
 - b) Romper únicamente AES-256
 - c) Romper RSA y ECC en tiempo polinómico
 - d) Romper ML-KEM en tiempo polinómico

- 17) **¿Qué problema ocurre si se utiliza el mismo nonce o IV en un algoritmo de flujo con la misma clave?**
- a) El algoritmo se bloque y no puede realizar el cifrado del nuevo texto
 - b) Se puede realizar un ataque por fuerza bruta para poder recuperar el texto original
 - c) Se puede recuperar el texto original mediante una operación XOR entre dos textos cifrados
 - d) Se duplica la longitud del texto cifrado
- 18) **En el contexto de las firmas digitales, ¿qué se cifra exactamente con la clave privada del emisor?**
- a) El hash del mensaje
 - b) La clave pública del destinatario
 - c) El mensaje completo en texto plano
 - d) El certificado digital de la Autoridad Certificadora
- 19) **¿Qué caracteriza al "Cifrado Homomórfico"?**
- a) Cambia automáticamente la clave de cifrado cada pocos segundos
 - b) Utiliza el mismo algoritmo para cifrar, firmar y comprimir datos
 - c) Solo puede ser descifrado si dos o más personas introducen sus claves simultáneamente
 - d) Permite realizar operaciones matemáticas sobre datos cifrados sin necesidad de descifrarlos primero
- 20) **Si un banco usa conexiones cifradas y aplica secretos efímeros, si un hacker roba hoy las claves que se usaron ayer de los usuarios, ¿podrá acceder a ver las transacciones de ayer hoy?**
- a) No, porque el banco pedirá un nuevo challenge y generará claves nuevas.
 - b) Sólo se pueden ver los datos de autenticación, pero no las transacciones
 - c) El hacker puede acceder a todo el historial de ayer
 - d) El hacker puede acceder a todo el historial de ayer pero no en claro sino cifrado

11.2 SOLUCIONES A LAS PREGUNTAS DE TEST

PREGUNTA	SOLUCIÓN
1	b
2	d
3	c
4	b
5	c
6	a
7	d
8	b
9	b
10	b
11	d
12	a
13	a
14	c
15	d
16	c
17	c
18	a
19	d
20	a

12 BIBLIOGRAFÍA

12.1 BIBLIOGRAFÍA BÁSICA

1. <https://www.ccn-cert.cni.es/es/800-guia-esquema-nacional-de-seguridad/513-ccn-stic-807-criptologia-de-empleo-en-el-ens/file.html> Guía CCN STIC 807, Criptología de empleo en el ENS
2. <https://www.youtube.com/@JorgeRamio> Class4Crypt Canal de Clases de criptografía del eminente Dr. Jorge Ramió (criptólogo de referencia en España)
3. <https://www.ccn-cert.cni.es/es/guias-de-acceso-publico-ccn-stic/6954-ccn-stic-221-guia-de-mecanismos-criptograficos-autorizados-por-el-ccn-1/file.html> Guía CCN STIC 221, Guía de Mecanismos criptográficos autorizados por el CCN
4. <http://www.grc.upv.es/biblioteca/cripto.pdf> Criptografía y seguridad en Computadores.

12.2 BIBLIOGRAFÍA PARA AMPLIAR EL TEMA

5. <https://csrc.nist.gov/projects/cryptographic-standards-and-guidelines> Página de estándares y guías de criptografía del NIST
6. <https://www.ccn.cni.es/index.php/es/docman/documentos-publicos/boletines-pytec/495-ccn-tec-009-recomendaciones-transicion-postcuantica-segura/file> Guía Técnica de recomendaciones para abordar la transición postcuántica.
7. <https://digital-strategy.ec.europa.eu/es/library/coordinated-implementation-roadmap-transition-post-quantum-cryptography> Una hoja de ruta de implementación coordinada para la transición a la criptografía post-cuántica
8. *Criptonomicón I. El código Enigma*. Neal Stephenson. ISBN-13 : 978-8466616447 Disponible en Amazon. Libro de referencia histórico-lúdica de la criptografía.